1. LOGO PRINCIPAL



DOSSIER TECHNIQUE

Guide de prise en main de la plateforme GoFix V1

WEB (PWA) • API REST • iOS / ANDROID • BACK-OFFICE • MISE EN LIGNE

Architecture, installation, configuration, déploiement sur le VPS Algérie Télécom, exploitation, sécurité et dépannage

Version 1.0 • Octobre 2026 • Alger

Objectif : permettre à toute personne qui reprend GoFix — développeur, administrateur système, exploitant ou modérateur — de comprendre la plateforme, de l'installer, de la mettre en ligne sur **gofix-digital.dz** et de l'exploiter en toute autonomie.

Élément	Valeur
Produit	GoFix — mise en relation particuliers ↔ professionnels et élèves ↔ professeurs (Algérie)
Version décrite	V1 (MVP complet + AI MATCH™ et TRUST SCORE™)
Domaine de production	gofix-digital.dz
Document de référence	Cahier des charges technique « 7 innovations propriétaires GOFIX » (septembre 2026)
Contient des mots de passe ?	**Non.** Les identifiants restent hors de ce document (voir A.5).

SOMMAIRE

Organisation du dossier et parcours de lecture conseillés

A **Cadre du document**
Finalité, public, état du projet, principes, confidentialité

B **La plateforme en bref**
Périmètre, rôles, fonctionnalités livrées, statut des 7 innovations, offres

C **Architecture technique**
Schéma, technologies, arborescence, données, adaptateurs, tâches planifiées

D **Prise en main développeur**
Installation locale, comptes de démonstration, tests, conventions, méthode de travail

E **Configuration**
Toutes les variables du fichier .env et l'exemple de production

F **Mise en ligne sur le VPS Algérie Télécom (aaPanel)**
Remplacer l'ancienne version pas à pas, vérifications, retour arrière, mises à jour

G **Services externes**
E-mail Admail, paiement SATIM (certification CIB), SMS, IA optionnelle, DNS

H **Back-office & exploitation**
Rôles, procédures de modération, flags, paramètres, sauvegardes, surveillance

I **Sécurité & conformité**
Mesures en place, audit d'octobre 2026, loi 18-07, procédure d'incident

J **Application mobile**
Configuration, compilation, publication sur les stores

K **Référence API**
Endpoints /api/v1 par module

L **Dépannage**
Symptômes fréquents, causes, solutions

M **Feuille de route & aide-mémoire**
Modules à venir, améliorations techniques, commandes utiles

A CADRE DU DOCUMENT

Finalité, public visé et état du projet

1. Finalité

Le cahier des charges « 7 innovations » décrit *ce que GoFix doit devenir*. Ce dossier décrit **ce qui est réellement construit en V1** et **comment s'en servir** : installer le projet, le configurer, le mettre en ligne sur le serveur Algérie Télécom, l'administrer et le faire évoluer.

2. Public et parcours de lecture

Profil	Sections prioritaires	Objectif
Direction / responsable produit	B, F (encadré de décision), H, M	Décider et piloter la mise en ligne
Développeur qui reprend le code	B, C, D, E, K, L	Être productif en une journée
Administrateur système	E, F, G, H.7–H.9, I, L	Déployer, sauvegarder, sécuriser
Modérateur / support	H.1–H.6	Traiter validations, litiges, tickets

3. État du projet (octobre 2026)

Brique	Statut	Commentaire
Site web (PWA) FR / AR	Prêt	Mobile d'abord (contrôlé à 360 px), arabe en RTL, thème sombre et clair
API REST + base MongoDB	Prêt	67 tests automatisés réussis (sécurité, paiement paramétrable, profil, notifications push, géolocalisation, non-régressions)
Back-office	Prêt	3 rôles admin, journal d'audit, flags et paramètres sans redéploiement
Application iOS / Android	À publier	Code prêt (Expo), compilation et publication sur les stores à faire (section J)
Paiement CIB / Edahabia	À certifier	Adaptateur SATIM prêt et paramétrable dans le back-office (onglet « Moyen de paiement ») ; certification sur cibweb.dz à dérouler (G.2)
E-mails transactionnels	À paramétrer	Paramétrable dans Admin → E-mails (serveur, adresses d'expédition et de réponse, e-mail de test) ; boîte Admail à saisir (G.1)
SMS (connexion par code)	Optionnel	Adaptateur prêt, désactivé par flag tant qu'aucun fournisseur n'est choisi

Brique	Statut	Commentaire
VISION, EDU AI, PRO AI, PASSPORT, VOICE	À venir	Affichés comme « à venir » dans le site et l'app ; flags désactivés

4. Principes appliqués

- **Souveraineté des données** — aucun CDN étranger, polices embarquées, aucun traceur publicitaire ; tout tourne sur le serveur en Algérie.
- **API d'abord** — toute la logique est dans l'API `/api/v1`, utilisée à l'identique par le site et l'application mobile.
- **Mobile d'abord** — chaque écran est vérifié à 360 px de large, en français et en arabe.
- **Règles côté serveur** — floutage des profils, droits d'abonnement et Trust Score sont calculés par l'API, jamais par l'interface seule.
- **Activation progressive** — chaque module s'active ou se coupe par *feature flag* depuis le back-office.
- **Privacy by design** (loi n° 18-07) — consentements horodatés, export et suppression des données, journal d'audit.
- **Aucune dépendance obligatoire à une IA générative** — AI MATCH et le chatbot fonctionnent par règles explicables.

5. Confidentialité des accès

> **Aucun mot de passe dans ce dossier**
>
> Les accès (panneau aaPanel, SSH root, Admail, espace cibweb.dz, comptes administrateur) ont été transmis par e-mail. Ils doivent être **changés dès la première connexion**, puis conservés dans un gestionnaire de mots de passe (Bitwarden, KeePass…) partagé uniquement avec les personnes habilitées. Ne jamais les écrire dans le code, dans le dépôt Git, dans ce document ou dans une conversation.

B LA PLATEFORME EN BREF

Périmètre fonctionnel, rôles et fonctionnalités livrées en V1

1. Périmètre

- **GoFix Services** — mise en relation entre particuliers et professionnels (plomberie, électricité, coiffure, ménage, pâtisserie…).
- **GoFix Academy** — soutien scolaire et cours particuliers, à domicile, en ligne ou en centre, avec professeurs vérifiés.
- **Socle commun** — comptes, profils, recherche, messagerie, rendez-vous, avis, abonnements, vérification des pièces, notifications, back-office.

2. Rôles utilisateurs

Rôle	Ce qu'il peut faire
Client	Rechercher (texte libre ou filtres), publier une demande ouverte ou ciblée, échanger par messagerie, prendre rendez-vous, ouvrir un litige, laisser un avis vérifié, gérer ses favoris.
Professionnel	Créer sa fiche en 7 étapes (métier, zones, disponibilités, photo, couverture, pièces), recevoir des demandes, proposer des rendez-vous, suivre son Trust Score. Accès gratuit de 30 jours ou 5 demandes, puis abonnement.
Professeur	Même logique que le professionnel, avec matières, niveaux et formats (domicile, en ligne, centre).
Élève	Demandes Academy, y compris multi-professeurs (jusqu'à 5). Consentement parental obligatoire sous l'âge défini dans les paramètres (18 ans par défaut).
Administrateurs	`super_admin`, `moderator`, `support` — détail en section H.2.

Un même compte peut cumuler plusieurs rôles (ex. client et professionnel) et passer de l'un à l'autre avec le sélecteur de mode du compte.

3. Fonctionnalités livrées par lot

Lot	Contenu livré
P1 – Socle	Inscription e-mail + téléphone (+213), connexion par e-mail ou téléphone, code SMS (flag), consentements horodatés, FR/AR (RTL), thème sombre/clair, export et suppression des données.
P2 – Tunnel pro / prof	Parcours en 7 étapes avec brouillon sauvegardé sur le serveur, photo, couverture, pièces justificatives, demande de nouvelle catégorie.
P3 – Catalogue	Recherche intelligente, filtres wilaya / catégorie, floutage serveur selon l'offre (matrice de déverrouillage), couvertures et miniatures (initiales si pas de photo).
P4 – Abonnements	Offres, commande, paiement CIB / Edahabia par page SATIM, factures PDF, relances avant expiration, expiration automatique.

Lot	Contenu livré
P5 – Mise en relation	Demandes ouvertes ou ciblées, messagerie, favoris, notifications, rendez-vous (proposer, confirmer, terminer, annuler, litige), avis vérifiés.
P6 – Assistant	Chatbot FAQ en français et en arabe, bascule vers un conseiller (création d'un ticket).
P7 – Modération	Validation des pièces, signalements, litiges, tickets, FAQ, taxonomie, journal d'audit, registre des traitements.
P8 – Confiance	TRUST SCORE™ v2 et AI MATCH™ (voir ci-dessous).

4. Les 7 innovations : statut en V1

Innovation	Statut	Ce qui est en place
AI MATCH™	Livré	Analyse d'une demande libre FR/AR (métier, lieu, urgence, jour, mode), filtres durs, score 0-100 sur critères pondérés et paramétrables, formule versionnée, 3 à 5 recommandations avec raisons lisibles, explication détaillée (« Pourquoi ? »), rotation d'exposition, enregistrement des retours, fonctionnement sans IA générative.
TRUST SCORE™	Livré	Score 0-100, statuts Insuffisant / Établi / Excellent, 4 sous-indicateurs (identité, réactivité, satisfaction, fiabilité), événements horodatés avec source, contestation, recalcul par un modérateur avec motif, aucun effet de l'abonnement (vérifié par test).
VISION™	À venir	Écran « à venir », flag `vision` désactivé.
EDU AI™	À venir	Flag `edu_ai` ; le matching Academy actuel repose sur matière, niveau, format et Trust.
PRO AI™	À venir	Flag `pro_ai` ; champs `ai{}` réservés dans les profils.
PASSPORT™	À venir	Flag `passport` ; champ `passport{}` réservé dans les profils.
VOICE™	À venir	Flag `voice` ; réutilisera le même schéma d'intention qu'AI MATCH.

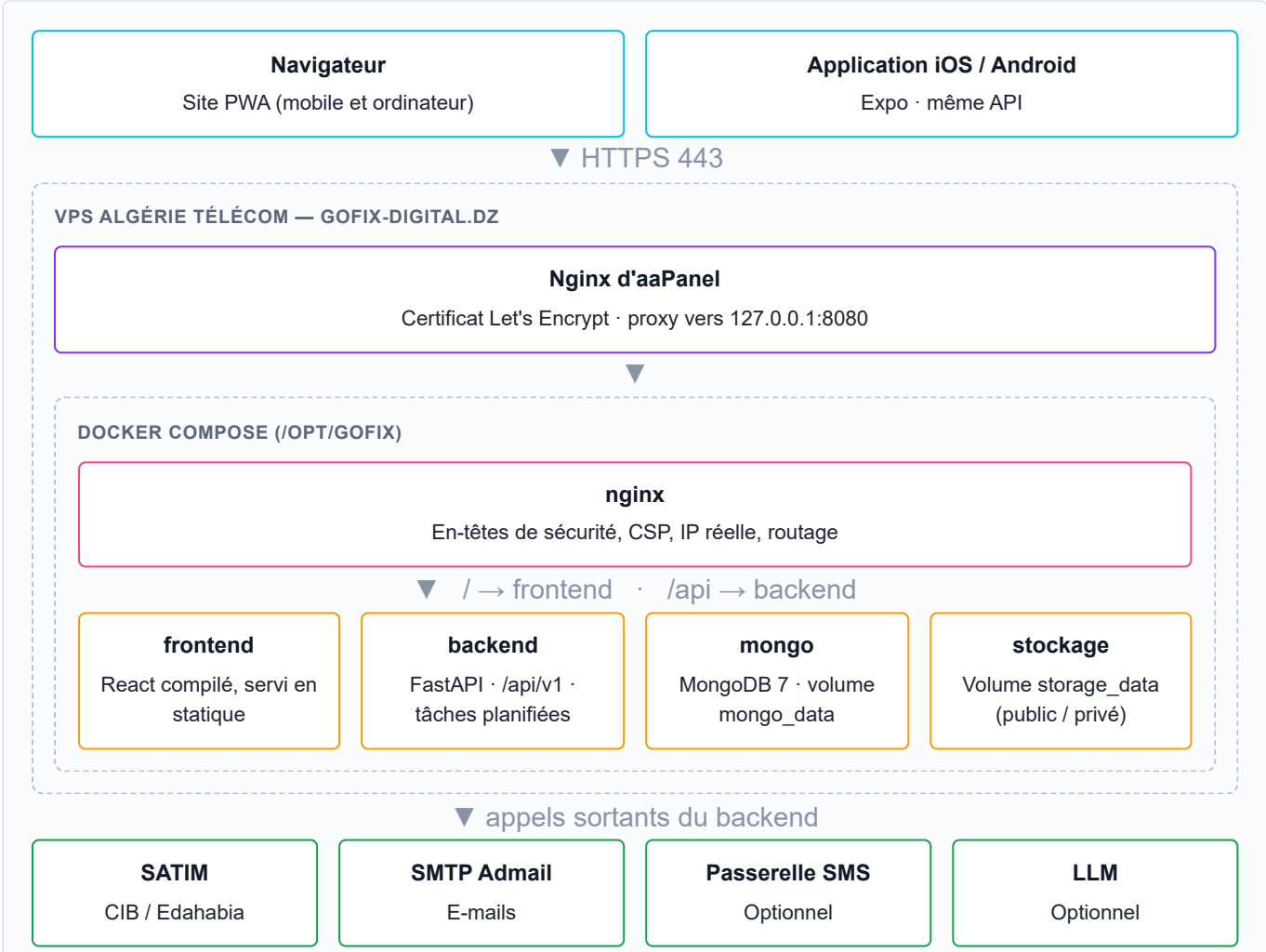
5. Offres (prix modifiables dans le back-office)

Public	Offre	Prix par défaut	Paramètre
Professionnels et professeurs	Pro	1 500 DA / mois	`plan_price_professional_pro`
Professionnels et professeurs	Premium	3 000 DA / mois	`plan_price_professional_premium`
Clients	Pro	500 DA / mois	`plan_price_client_pro`
Clients	Premium	1 000 DA / mois	`plan_price_client_premium`
Élèves / étudiants	Pass étudiant	300 DA / mois	`plan_price_student_student_pass`

C ARCHITECTURE TECHNIQUE

Composants, technologies, organisation du code et des données

1. Vue d'ensemble (cible de production)



2. Technologies

Couche	Technologies
Site web	React 19 (Create React App + craco), Tailwind CSS 3, composants shadcn/ui, React Query, axios, PWA (service worker), police Tajawal embarquée
Application mobile	React Native avec Expo SDK 57, Expo Router, React Query, axios, SecureStore pour les jetons
API	Python 3.11, FastAPI, Motor (MongoDB asynchrone), Pydantic, bcrypt, PyJWT, Pillow (images), fpdf2 (factures PDF)
Base de données	MongoDB 7 (index et TTL créés automatiquement au démarrage)

Couche	Technologies
Infrastructure	Docker Compose, Nginx 1.27, aaPanel sur le VPS (proxy HTTPS)
Tests	pytest + httpx contre une vraie base MongoDB dédiée (`gofix_test`)

3. Organisation du dépôt

```
gofix-mvp/
├─ backend/                API FastAPI
│  ├─ app/
│  │  ├─ main.py           application, middlewares, en-têtes, démarrage (index, flags, super-admin)
│  │  ├─ core/             config (.env), db, security (bcrypt/JWT), deps (auth, rôles), ratelimit, safety
(garde-fous prod)
│  │  ├─ adapters/         payment (mock | satim), email (console | smtp), sms (console | http), llm,
storage
│  │  ├─ services/         trust, matching, intent, billing, scheduler, notify, audit, visibility,
config_store…
│  │  ├─ api/v1/           auth, users, catalog, marketplace, onboarding, provider, requests, jobs, match,
│  │  │                    trust_api, billing, social, chatbot, public, admin, admin_ops, admin_taxonomy
│  │  ├─ data/             valeurs par défaut (flags, paramètres), référentiels, registre des traitements
│  │  └─ seed.py           référentiels (+ démo hors production)
│  └─ tests/               67 tests d'intégration
├─ frontend/               site React (src/pages, components, i18n, lib, hooks, services)
├─ mobile/                 application Expo (src/app = écrans, src/ui, src/i18n synchronisé depuis le web)
├─ deploy/nginx/           configuration Nginx (conf.d) et certificats éventuels (certs)
├─ scripts/                deploy.sh, package_release.ps1, backup_mongo.sh, restore_mongo.sh, build_docs.py
├─ docs/                   ARCHITECTURE.md, SECURITY_AUDIT.md, ce dossier
├─ docker-compose.yml      mongo, backend, frontend, nginx (+ service de tests)
└─ .env.example            modèle de configuration
```

4. Parcours d'une requête

1. Le site ou l'app appelle `https://gofix-digital.dz/api/v1/…` avec le jeton `Authorization: Bearer` (accès de 15 min).
2. aaPanel termine le HTTPS et transmet la requête au Nginx de GoFix, qui détermine l'IP réelle du client et ajoute les en-têtes de sécurité.
3. FastAPI valide les données (Pydantic), vérifie l'identité, le rôle et le statut du compte (suspendu = refusé), applique les limites de débit.
4. La logique métier lit et écrit dans MongoDB ; les actions sensibles écrivent une ligne dans `audit_logs` .
5. Réponse JSON. Une erreur renvoie `{"detail": "code_erreur"}` , traduit par l'interface ; une erreur interne ne montre jamais de trace.
6. Quand le jeton expire, l'interface le renouvelle automatiquement (rotation du jeton de rafraîchissement, réutilisation détectée et bloquée).

5. Principales collections MongoDB

Collection	Rôle
`users`	Comptes, rôles, mode actif, rôle admin, statut (actif, suspendu, supprimé), préférences, tuteur

Collection	Rôle
`professional_profiles` / `teacher_profiles`	Fiches publiques : métier ou matières, zones, disponibilités, médias, pièces (privées), Trust, accès gratuit
`requests`	Demandes des clients et élèves, destinataires et réponses
`conversations` / `messages`	Messagerie
`jobs` / `reviews`	Rendez-vous (cycle de vie complet, litiges) et avis vérifiés
`trust_events` / `trust_flags` / `trust_contests`	Événements du Trust Score, alertes anti-fraude, contestations
`match_results` / `match_feedback`	Décisions AI MATCH tracées (formule, raisons, durée) et retours
`payment_orders` / `subscriptions` / `invoices`	Commandes, abonnements, factures
`feature_flags` / `settings`	Activation des modules et paramètres modifiables dans le back-office
`audit_logs` / `consents`	Journal d'audit, consentements horodatés
`login_attempts` / `refresh_tokens` / `otp_codes`	Sécurité de connexion (purge automatique par index TTL)

Schéma détaillé, champs et index : `docs/ARCHITECTURE.md`.

6. Adaptateurs (choisis par variables d'environnement)

Adaptateur	Mode développement	Mode réel
Paiement	« Paiement de test (simulé) »	SATIM : CIB / Edahabia — choisi et paramétré dans le back-office (le .env sert de valeur par défaut) ; le mode simulé est refusé en production
E-mail	`console` (affiché dans les logs)	`smtp` : boîte Admail (port 465 SSL ou 587 STARTTLS)
SMS	`console` (code dans les logs)	`http` : passerelle SMS algérienne
IA (chatbot)	`none`	`openai_compatible` + flag `chatbot_llm`
Stockage	`local` : volume Docker	Identique en V1 ; stockage objet (S3 / MinIO) prévu

7. Tâches planifiées

Le backend exécute une boucle toutes les **15 minutes** (`services/scheduler.py`) :

- expiration des abonnements échus, avec notification et ligne d'audit ;
- relances avant expiration (J-7, J-3, J-1 par défaut, paramètre `subscription_reminder_days`) ;

- expiration des commandes non payées après 30 minutes (`payment_timeout_minutes`) ;
- validation automatique des rendez-vous terminés sans litige après 72 h, et rappels des rendez-vous à venir.

D

PRISE EN MAIN DÉVELOPPEUR

Installer, tester et faire évoluer le projet sur un poste de travail

1. Prérequis

- **Docker Desktop** (Windows / macOS) ou Docker Engine + plugin Compose (Linux).
- **Git**. Le dossier n'est pas encore versionné : créer un **dépôt Git privé** (GitHub, GitLab ou serveur interne) est la toute première action à faire.
- **Node.js 20** pour l'application mobile (et pour lancer le site hors Docker).
- Un éditeur : VS Code recommandé.

2. Installation locale en 5 commandes

```
cp .env.example .env                    # puis renseigner JWT_SECRET, ADMIN_EMAIL, ADMIN_PASSWORD
openssl rand -hex 32                    # valeur pour JWT_SECRET
docker compose up -d --build            # mongo + backend + frontend + nginx
docker compose exec backend python -m app.seed   # référentiels + données de démonstration
# ouvrir http://localhost  (back-office : http://localhost/admin)
```

Bon à savoir

- Le super-administrateur défini par `ADMIN_EMAIL` / `ADMIN_PASSWORD` est créé, ou son mot de passe réinitialisé, à chaque démarrage.
- Le seed est idempotent : on peut le relancer sans créer de doublons.
- La documentation interactive de l'API est disponible en local sur `http://localhost/api/docs` (masquée en production).

3. Comptes de démonstration (local uniquement)

Mot de passe commun : `GoFix@Demo2026`. Ces comptes ne doivent **jamais** exister en production : le seed complet y est refusé.

Compte	Usage
`client@gofix.dz`	Client avec conversation et rendez-vous en cours avec `pro@gofix.dz`
`premium.client@gofix.dz`	Client avec abonnement Premium actif (profils déverrouillés)
`eleve@gofix.dz`	Élève (Academy)
`pro@gofix.dz` / `prof@gofix.dz`	Professionnel / professeur avec accès gratuit en cours (tableau de bord)
`attente.pro@gofix.dz`	Professionnel en attente de validation des pièces
`nouveau.pro@gofix.dz` / `nouveau.prof@gofix.dz`	Comptes sans fiche, pour tester le tunnel d'inscription

Compte	Usage
`moderateur@gofix.dz` / `support@gofix.dz`	Rôles admin moderator et support
`pro02…@demo.gofix.dz`, `client01…@demo.gofix.dz`	Profils et clients générés (catalogue réaliste avec historique d'avis)

4. Tests automatisés

```
docker compose --profile test run --rm tests     # base dédiée gofix_test, supprimée à la fin — 67 tests
```

Ils couvrent : profils suspendus jamais affichés, floutage serveur, AI MATCH (FR/AR, raisons, traçabilité), Trust Score (statuts, non achetable), cycle des rendez-vous et litiges, paiements (succès, échec, double callback, callback falsifié, expiration), Academy, chatbot, et la sécurité (verrouillage des comptes, IP falsifiée, droits admin, jeton de réinitialisation à usage unique, contenu réel des fichiers, effacement des données, paiement fictif refusé en production). **Règle : aucun déploiement si un test échoue.**

5. Application mobile en développement

```
cd mobile
npm install
EXPO_PUBLIC_API_URL=http://192.168.1.20 npx expo start   # IP du PC sur le réseau local, puis scanner le QR avec Expo Go
```

6. Conventions à respecter

Sujet	Règle
Textes et langues	Aucun texte en dur. Dictionnaires `frontend/src/i18n/` : `fr.js` + `fr.lots.js` + `fr.lots2.js` fusionnés (idem en `ar`). Après modification : `npm run i18n:sync` dans `mobile/`.
Erreurs	L'API renvoie un code (`{"detail": "email_taken"}`) ; sa traduction se trouve dans `errors.*` des dictionnaires.
Mobile et RTL	Vérifier chaque écran à 360 px en FR et en AR ; utiliser les propriétés logiques (`ms-`, `me-`, `start`, `end`) ; zones tactiles d'au moins 44 px.
Formats	Dates JJ/MM/AAAA à l'heure d'Alger, montants en DA, téléphones au format +213 (affichés 05 xx xx xx xx).
Sécurité	Toute règle d'accès est vérifiée côté API ; toute action admin sensible appelle `audit()` ; aucun secret dans le code.
Nouveau module	Derrière un feature flag déclaré dans `backend/app/data/defaults.py`, désactivé par défaut.
Contenu externe	Aucun script, police ou image d'un domaine tiers : la politique de sécurité (CSP) le bloquerait.

7. Méthode pour ajouter une fonctionnalité

1. Créer une branche Git (`feature/…`).
2. API : modèle Pydantic, route dans `api/v1/` , logique dans `services/` , contrôle des droits, audit si besoin.
3. Écrire le test dans `backend/tests/` et lancer toute la suite.
4. Interface web, puis mobile, avec les textes FR + AR.
5. Vérifier à 360 px (FR et AR), en thème sombre et clair.
6. Mettre à jour `docs/ARCHITECTURE.md` (endpoints, collections) et, si besoin, ce dossier.
7. Revue de code, fusion, puis déploiement (section F.11).

E CONFIGURATION

Le fichier .env : une seule source de vérité, jamais versionnée

1. Variables

Variable	Rôle	Valeur en production
`APP_ENV`	Environnement ; `production` active les garde-fous de démarrage	`production`
`DB_NAME`	Nom de la base	`gofix`
`MONGO_URL`	Connexion MongoDB	`mongodb://user:mdp@mongo:27017/?authSource=admin`
`MONGO_ROOT_USER` / `_PASSWORD`	Active l'authentification MongoDB (sur un volume neuf)	Valeurs fortes
`FRONTEND_URL`	URL publique (e-mails, retours de paiement)	`https://gofix-digital.dz`
`CORS_ORIGINS`	Origines autorisées par l'API	`https://gofix-digital.dz,https://www.gofix-digital.dz`
`JWT_SECRET`	Signature des jetons	`openssl rand -hex 32`
`JWT_ACCESS_TTL_MINUTES` / `JWT_REFRESH_TTL_DAYS`	Durée des jetons	`15` / `30`
`ADMIN_EMAIL` / `ADMIN_PASSWORD`	Super-administrateur créé au démarrage	Adresse de l'entreprise ; 12 caractères minimum
`STORAGE_BACKEND` / `STORAGE_LOCAL_ROOT`	Stockage des fichiers	`local` / `/data/storage`
`EMAIL_PROVIDER`, `SMTP_HOST`, `SMTP_PORT`, `SMTP_USER`, `SMTP_PASSWORD`, `SMTP_FROM`, `SMTP_TLS`	Envoi des e-mails : valeurs de secours seulement, la configuration saisie dans Admin → E-mails est prioritaire (465 = SSL ; 587 = STARTTLS)	`smtp` + paramètres Admail (G.1)
`SMS_PROVIDER`, `SMS_HTTP_URL`, `SMS_HTTP_TOKEN`, `SMS_SENDER_ID`	Envoi des codes SMS	`console` tant que le flag OTP est coupé

Variable	Rôle	Valeur en production
`PAYMENT_PROVIDER`, `SATIM_BASE_URL`, `SATIM_USERNAME`, `SATIM_PASSWORD`, `SATIM_TERMINAL_ID`	Valeurs **par défaut** du paiement, utilisées tant que rien n'est enregistré dans le back-office (onglet « Moyen de paiement »)	Peuvent rester vides : tout se règle dans le back-office (G.2)
`CONFIG_ENCRYPTION_KEY`	Clé de chiffrement des secrets saisis dans le back-office (mots de passe SATIM et SMTP). À défaut, dérivée de `JWT_SECRET`	`openssl rand -hex 32` (recommandé)
`LLM_PROVIDER`, `LLM_BASE_URL`, `LLM_API_KEY`, `LLM_MODEL`	Reformulation du chatbot (facultatif)	`none`
`MOBILE_APP_SCHEME`	Retour de paiement vers l'application	`gofix`
`HTTP_BIND` / `HTTPS_BIND`	Ports publiés par le Nginx de GoFix	`127.0.0.1:8080` / `127.0.0.1:8443` (aaPanel)
`EXPOSE_API_DOCS`	Affiche `/api/docs` en production	`false`
`ALLOW_MOCK_PAYMENTS`	Autorise le paiement fictif en production	`false` (serveur de préproduction uniquement)

2. Exemple de .env de production (gofix-digital.dz)

```
APP_ENV=production
DB_NAME=gofix
MONGO_ROOT_USER=gofix_root
MONGO_ROOT_PASSWORD=<openssl rand -hex 24>
MONGO_URL=mongodb://gofix_root:<même mot de passe>@mongo:27017/?authSource=admin
FRONTEND_URL=https://gofix-digital.dz
CORS_ORIGINS=https://gofix-digital.dz,https://www.gofix-digital.dz
JWT_SECRET=<openssl rand -hex 32>
JWT_ACCESS_TTL_MINUTES=15
JWT_REFRESH_TTL_DAYS=30
ADMIN_EMAIL=admin@gofix-digital.dz
ADMIN_PASSWORD=<12 caractères minimum, lettres et chiffres>
STORAGE_BACKEND=local
STORAGE_LOCAL_ROOT=/data/storage
EMAIL_PROVIDER=smtp
SMTP_HOST=<fourni par Algérie Télécom>
SMTP_PORT=465
SMTP_USER=no-reply@gofix-digital.dz
SMTP_PASSWORD=<mot de passe de la boîte>
SMTP_FROM=no-reply@gofix-digital.dz
SMTP_TLS=true
SMS_PROVIDER=console
CONFIG_ENCRYPTION_KEY=<openssl rand -hex 32>
# Paiement : à paramétrer dans le back-office → « Moyen de paiement » (aucune variable SATIM nécessaire ici)
LLM_PROVIDER=none
MOBILE_APP_SCHEME=gofix
HTTP_BIND=127.0.0.1:8080
HTTPS_BIND=127.0.0.1:8443
```

> **Garde-fous de production**
>
> Avec `APP_ENV=production`, l'API **refuse de démarrer** et explique pourquoi dans les logs si : `JWT_SECRET` fait moins de 32 caractères ou est un mot courant, `ADMIN_PASSWORD` est trop faible, `FRONTEND_URL` n'est pas en https, `CORS_ORIGINS` contient « localhost », Elle avertit (sans bloquer) si le paiement en ligne n'est pas encore paramétré, si les e-mails ou SMS restent en mode console ou si MongoDB n'a pas de mot de passe. Tant que SATIM n'est pas paramétré, les commandes d'abonnement répondent « paiement momentanément indisponible » : le mode simulé n'est jamais utilisé en production.

Après toute modification du `.env` : `docker compose up -d` (les conteneurs concernés redémarrent). Protéger le fichier : `chmod 600 .env`.

F MISE EN LIGNE SUR LE VPS

Remplacer l'ancienne version de gofix-digital.dz sur le serveur Algérie Télécom géré par aaPanel

Décision : pouvez-vous retirer l'ancienne version vous-même ?

Oui, en suivant cette section dans l'ordre, à quatre conditions :

1. **Sauvegarder entièrement l'ancienne version** (fichiers et base) et télécharger la sauvegarde sur un autre support avant toute modification (F.2).
2. **Ne pas la supprimer tout de suite** : la garder archivée sur le serveur au moins 30 jours, pour pouvoir revenir en arrière en quelques minutes.
3. **Basculer le domaine seulement après** avoir testé la nouvelle version sur le serveur lui-même (F.8, test par tunnel SSH).
4. **Comptes et données** : les utilisateurs de l'ancienne version (dont son compte administrateur) ne sont **pas** repris automatiquement. S'il y a de vrais inscrits à conserver, prévoir une migration avant la bascule ; sinon, la V1 démarre sur une base propre.

F.0 Vue d'ensemble de l'opération

Étape	Action	Durée indicative	Impact visiteurs
F.1	Premier accès et sécurisation du serveur	30 min	Aucun
F.2	Inventaire et sauvegarde de l'ancienne version	30 min	Aucun
F.3	Préparation du serveur (Docker, mémoire)	20 min	Aucun
F.4 – F.6	Dépôt du code, .env, démarrage de GoFix V1	30 min	Aucun (ancienne version toujours en ligne)
F.7 – F.8	Reverse proxy aaPanel, HTTPS, bascule	15 min	Coupure de quelques secondes
F.9	Vérifications après mise en ligne	30 min	—

F.1 Premier accès et sécurisation

1. **SSH** : `ssh root@<IP publique du VPS>`. Le serveur impose de changer le mot de passe root à la première connexion : choisir un mot de passe long et unique.
2. **Mettre le système à jour** : `apt update && apt -y upgrade` (Debian/Ubuntu ; adapter si le VPS est sous une autre distribution).
3. **Clé SSH** : depuis votre PC, `ssh-keygen -t ed25519` puis `ssh-copy-id root@<IP>`. Une fois la connexion par clé vérifiée, mettre `PasswordAuthentication no` dans `/etc/ssh/sshd_config` puis `systemctl restart ssh`.
4. **aaPanel** : changer le mot de passe du panneau, garder secrète l'« entrée de sécurité » (le chemin après le port 8888), activer la double authentification si elle est proposée, et limiter l'accès au port 8888 à votre IP (aaPanel → *Security*).

5. **Pare-feu** : n'ouvrir que 22 (SSH), 80, 443 et 8888 (restreint). Ne jamais ouvrir 8080, 8443 ni 27017.
6. **Changer tous les mots de passe reçus par e-mail** : aaPanel, root, Admail, cibweb.dz, et le compte administrateur de l'ancienne plateforme.

F.2 Inventaire et sauvegarde de l'ancienne version

1. aaPanel → **Website** : ouvrir le site `gofix-digital.dz` et noter son type (PHP, Node, proxy…), son dossier racine (souvent `/www/wwwroot/gofix-digital.dz`) et sa configuration SSL.
2. aaPanel → **Databases** : lancer une sauvegarde de chaque base utilisée par l'ancien site, puis la télécharger.
3. Vérifier si l'ancienne version tourne sous Docker : `docker ps` (si la commande existe).
4. Archiver les fichiers et la configuration Nginx du site :

```
mkdir -p /root/ancienne-version
tar czf /root/ancienne-version/site-$(date +%F).tar.gz /www/wwwroot/gofix-digital.dz
cp -r /www/server/panel/vhost/nginx /root/ancienne-version/vhost-nginx-$(date +%F)   # configuration du site
ls -lh /root/ancienne-version
```

Télécharger ensuite le dossier `/root/ancienne-version` sur votre PC (aaPanel → *Files*, ou `scp -r root@<IP>:/root/ancienne-version .`).

F.3 Préparer le serveur

```
free -h ; nproc ; df -h /           # conseillé : 2 vCPU, 4 Go de RAM, 20 Go libres
grep -c avx /proc/cpuinfo           # doit être > 0 : MongoDB 7 exige l'instruction AVX
# Mémoire d'échange de 2 Go (la compilation du site en a besoin si la RAM est ≤ 4 Go)
fallocate -l 2G /swapfile && chmod 600 /swapfile && mkswap /swapfile && swapon /swapfile
echo '/swapfile none swap sw 0 0' >> /etc/fstab
# Docker : aaPanel → App Store → Docker, ou :
curl -fsSL https://get.docker.com | sh
docker compose version
```

> **Si « grep -c avx » affiche 0**
>
> Le processeur virtuel ne transmet pas AVX : MongoDB 7 ne démarrera pas (erreur « Illegal instruction »). Demander à Algérie Télécom d'activer le mode CPU « host » sur la VM, ou passer l'image en `mongo:4.4` dans `docker-compose.yml` en remplaçant `mongosh` par `mongo` dans le healthcheck.

F.4 Déposer le code

Option A — dépôt Git privé (recommandé) :

```
mkdir -p /opt/gofix && cd /opt/gofix
git clone <url-du-depot-prive> .
```

Option B — archive depuis le PC (Windows) : le script `scripts\package_release.ps1` crée `gofix-release.tar.gz` à côté du dossier `gofix-mvp`. L'archive ne contient ni `.env`, ni `node_modules`, ni l'application mobile, ni les sauvegardes, et les scripts y sont convertis au format Linux.

```
# PowerShell, dans le dossier gofix-mvp
powershell -ExecutionPolicy Bypass -File scripts\package_release.ps1
scp ..\gofix-release.tar.gz root@<IP>:/opt/
# sur le serveur (première fois)
mkdir -p /opt/gofix && tar xzf /opt/gofix-release.tar.gz -C /opt/gofix
```

F.5 Fichier .env de production

```
cd /opt/gofix
cp .env.example .env && chmod 600 .env
nano .env        # reprendre l'exemple de la section E.2 ; générer chaque secret avec openssl rand -hex 32
```

Points clés : `APP_ENV=production`, `HTTP_BIND=127.0.0.1:8080`, `HTTPS_BIND=127.0.0.1:8443` (aaPanel garde les ports 80 et 443), `MONGO_ROOT_USER` / `MONGO_ROOT_PASSWORD` renseignés **avant** le premier démarrage. Ils ne s'appliquent qu'à un volume MongoDB neuf.

F.6 Démarrer GoFix V1

```
cd /opt/gofix
bash scripts/deploy.sh        # 5 à 15 min la première fois ; se termine par « Déploiement terminé »
```

Le script `scripts/deploy.sh` vérifie Docker et le `.env`, sauvegarde la base si elle tourne déjà, construit et démarre les 4 services, attend que `/api/health` réponde, charge les référentiels (wilayas, métiers, matières, offres, FAQ) puis nettoie les anciennes images. En cas d'échec, il affiche l'état des services et les derniers logs du backend. Équivalent manuel :

```
docker compose up -d --build
docker compose ps                                              # 4 services « Up », backend « healthy »
curl -s http://127.0.0.1:8080/api/health                       # {"status":"ok","db":true,…}
docker compose exec backend python -m app.seed --reference-only
```

> **Si le backend redémarre en boucle**
>
> Lire `docker compose logs backend` : un message « Unsafe production configuration » liste précisément les valeurs du `.env` à corriger.

F.7 Reverse proxy et HTTPS dans aaPanel

1. aaPanel → **Website** → site `gofix-digital.dz` (vérifier que `www.gofix-digital.dz` figure dans les domaines).
2. Onglet **SSL** → *Let's Encrypt* → cocher les deux domaines → *Apply*, puis activer **Force HTTPS**.
3. Onglet **Reverse proxy** → *Add* : nom `gofix`, URL cible `http://127.0.0.1:8080`, domaine envoyé `$host`.
4. Onglet **Config** (fichier Nginx du site) : vérifier ou compléter le bloc du proxy comme ci-dessous, puis enregistrer.

```
client_max_body_size 10m;           # photos et pièces justificatives (jusqu'à 10 Mo)
location / {
    proxy_pass http://127.0.0.1:8080;
    proxy_set_header Host $host;
    proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;   # indispensable : IP réelle des visiteurs
    proxy_set_header X-Forwarded-Proto $scheme;
    proxy_read_timeout 60s;
}
```

> **Pourquoi l'en-tête X-Forwarded-For est indispensable**
>
> Les limites anti-abus (connexion, mot de passe oublié, formulaires) fonctionnent par adresse IP. Sans cet en-tête, tous les visiteurs auraient l'IP du serveur et se bloqueraient mutuellement. Le Nginx de GoFix ne fait confiance qu'au proxy local, donc un visiteur ne peut pas usurper une IP.

F.8 Tester puis basculer

1. **Test avant bascule** : depuis votre PC, ouvrir un tunnel `ssh -L 8080:127.0.0.1:8080 root@<IP>`, puis naviguer sur `http://localhost:8080` : connexion avec `ADMIN_EMAIL`, back-office, recherche, création d'un compte test.
2. **Bascule** : appliquer le reverse proxy (F.7). Les fichiers de l'ancienne version restent sur le disque, intacts, mais ne sont plus servis.
3. Vider le cache du navigateur et ouvrir `https://gofix-digital.dz` : la V1 doit s'afficher avec le cadenas.
4. Dérouler les vérifications de F.9. Au bout de 30 jours sans problème, supprimer l'ancienne version (fichiers et base) dans aaPanel.

F.9 Vérifications après mise en ligne

Test	Résultat attendu
`https://gofix-digital.dz` sur téléphone	Cadenas, page d'accueil en FR ; drapeau algérien → arabe RTL
`http://gofix-digital.dz`	Redirection automatique vers https
`https://gofix-digital.dz/api/health`	`{"status":"ok","db":true,…}`
`https://gofix-digital.dz/api/docs`	404 (documentation masquée en production)
Connexion `/admin` avec `ADMIN_EMAIL`	Back-office complet
Inscription d'un compte de test	Compte créé, consentements enregistrés
« Mot de passe oublié » sur ce compte	E-mail reçu depuis `no-reply@gofix-digital.dz`, lien fonctionnel
Tunnel pro : envoi d'une photo et d'une pièce	Envoi accepté (sinon voir `client_max_body_size`)
Paiement (environnement de test SATIM)	Page SATIM, retour sur `/payment/result`, abonnement activé une seule fois
5 mauvais mots de passe sur un compte test	Blocage « Trop de tentatives » pour cette IP uniquement

Test	Résultat attendu
En-têtes : `curl -sI https://gofix-digital.dz`	`Content-Security-Policy` , `X-Frame-Options: DENY` , HSTS (si activé dans aaPanel)
Sauvegarde : `./scripts/backup_mongo.sh`	« Backup OK » et fichier dans `backups/`

F.10 Retour arrière

- **Revenir à l'ancienne version** : dans aaPanel, supprimer le reverse proxy du site et restaurer sa configuration sauvegardée en F.2 (`/root/ancienne-version/vhost-nginx-…`), puis `docker compose down` dans `/opt/gofix` .
- **Revenir à une version précédente de GoFix** : `git checkout <tag précédent>` puis `docker compose up -d --build` ; si la base a été modifiée, `./scripts/restore_mongo.sh backups/<fichier>` .

F.11 Mises à jour ultérieures

```
# Sur le PC : nouvelle archive puis envoi
powershell -ExecutionPolicy Bypass -File scripts\package_release.ps1
scp ..\gofix-release.tar.gz root@<IP>:/opt/
# Sur le serveur : sauvegarde + installation + redémarrage + vérification (le .env n'est jamais écrasé)
bash /opt/gofix/scripts/deploy.sh /opt/gofix-release.tar.gz
# Avec un dépôt Git à la place de l'archive :
cd /opt/gofix && git pull && bash scripts/deploy.sh
```

Conseil : étiqueter chaque version mise en ligne (`git tag v1.0.1`) pour pouvoir revenir en arrière précisément.

G SERVICES EXTERNES

E-mail, paiement en ligne, SMS, IA et nom de domaine

G.1 E-mails avec Admail (Algérie Télécom)

Admail (`admail.djaweb.dz/new2017`) gère les boîtes du domaine `gofix-digital.dz` . GoFix envoie ses e-mails (réinitialisation de mot de passe…) via le serveur SMTP d'Algérie Télécom avec une boîte dédiée.

1. **Créer la boîte d'envoi** : Admail → *Gérer mes comptes* → *Ajouter un nouveau compte* → Nom « GoFix », login `no-reply` , bouton *Créer le mot de passe* (le copier dans le gestionnaire de mots de passe), type *Basic*, petit quota → *Envoyer*.
2. **Boîtes utiles en plus** : `contact@` (affichée sur le site), `support@` (tickets), `admin@` (compte `ADMIN_EMAIL`).
3. **Obtenir les paramètres SMTP sortants** : le guide Admail ne les donne pas. Les demander au support (`support@algerietelecom.dz`) : nom du serveur SMTP, port (465 SSL ou 587 STARTTLS), authentification requise, limites d'envoi par heure ou par jour.
4. **Renseigner le .env** : `EMAIL_PROVIDER=smtp` , `SMTP_HOST` , `SMTP_PORT` , `SMTP_USER=no-reply@gofix-digital.dz` , `SMTP_PASSWORD` , `SMTP_FROM=no-reply@gofix-digital.dz` , puis `docker compose up -d` .
5. **Tester** avec « Mot de passe oublié » et vérifier la réception, y compris dans les courriers indésirables.
6. **Délivrabilité** : demander à Algérie Télécom de confirmer les enregistrements SPF (et DKIM si disponible) du domaine.

> **Renouvellement de l'abonnement messagerie**
>
> Admail affiche une alerte 15 jours avant la fin de l'abonnement. Sans renouvellement, les boîtes s'arrêtent, ainsi que les e-mails de réinitialisation de mot de passe. À inscrire dans le calendrier de l'entreprise.

G.2 Paiement en ligne CIB / Edahabia (SATIM)

Fonctionnement dans GoFix

1. L'utilisateur choisit une offre ; l'API crée une commande au prix fixé par le serveur et l'enregistre chez SATIM (`register.do`).
2. Le navigateur ou l'app est redirigé vers la **page de paiement hébergée par SATIM** : GoFix ne voit jamais les numéros de carte.
3. SATIM renvoie vers `https://gofix-digital.dz/api/v1/billing/callback/satim` ; l'API vérifie le statut directement auprès de SATIM (`confirmOrder.do`).
4. Si le paiement est confirmé, l'abonnement est activé **une seule fois**, même en cas de retours multiples, et la facture PDF est générée.

Certification (espace cibweb.dz → « Certification sites web marchands »)

1. Avoir un contrat de paiement en ligne avec la banque de l'entreprise (adhésion e-paiement CIB) ; la banque transmet les accès à l'environnement de **test** SATIM (URL, identifiant, mot de passe, terminal).
2. Back-office (super-admin) → onglet **Moyen de paiement** : choisir « SATIM – CIB / Edahabia », environnement « test », saisir l'URL de l'API, l'identifiant, le mot de passe et le Terminal ID fournis par la banque, puis

Enregistrer et *Tester la connexion*. Aucun redémarrage n'est nécessaire. Communiquer à la SATIM l'URL de retour affichée sur le même écran.

3. Vérifier les pages exigées par la certification : CGV (`/legal/cgv`), mentions légales (`/legal/mentions`) et confidentialité (`/legal/privacy`), complétées avec les informations réelles de la société (raison sociale, RC, NIF, adresse, contact).
4. Dérouler les scénarios demandés par SATIM (paiement accepté, refusé, annulé, carte invalide…) et fournir les captures et numéros de commande visibles dans le back-office → *Paiements*.
5. Après validation, la banque fournit les accès de **production** : dans le même onglet, passer l'environnement sur « Production SATIM », remplacer l'URL, l'identifiant, le mot de passe et le terminal, enregistrer, tester, puis faire un premier paiement réel de faible montant.

> **Sécurité de l'écran « Moyen de paiement »**
>
> - Réservé au **super-admin** ; chaque enregistrement et chaque test sont inscrits au journal d'audit, sans aucun secret.
> - Le mot de passe SATIM est **chiffré** en base et n'est jamais réaffiché : le laisser vide conserve celui qui est enregistré.
> - Le chiffrement utilise `CONFIG_ENCRYPTION_KEY` (ou, à défaut, `JWT_SECRET`) : si cette clé change, ressaisir le mot de passe SATIM — l'écran le signale.
> - « Tester la connexion » vérifie que le serveur SATIM répond et accepte les identifiants, sans débiter de carte ; seul un paiement de test complet valide toute la chaîne.
> - Le « paiement de test (simulé) » est impossible à sélectionner en production : il activerait des abonnements sans paiement.

> **Si l'ancienne version était déjà certifiée**
>
> La certification porte sur l'intégration technique du site. Comme la V1 est une nouvelle intégration, vérifier son statut dans l'espace cibweb.dz et, en cas de doute, demander à la SATIM si une nouvelle recette est nécessaire.

G.3 SMS (connexion par code)

Désactivé par défaut (flag `auth_phone_otp`). Pour l'activer : choisir une passerelle SMS algérienne avec API HTTP, puis renseigner `SMS_PROVIDER=http` , `SMS_HTTP_URL` , `SMS_HTTP_TOKEN` , `SMS_SENDER_ID=GOFIX` . L'adaptateur envoie un `POST` JSON `{"to", "from", "text"}` avec l'en-tête `Authorization: Bearer <token>` ; l'adapter si la passerelle attend un autre format (`backend/app/adapters/sms.py`). Activer ensuite le flag dans le back-office. Limites : 3 envois par 10 minutes et 5 essais par code.

G.4 IA générative (facultatif)

Le chatbot répond à partir de la FAQ, sans IA externe. Une reformulation par un modèle de langage est possible (`LLM_PROVIDER=openai_compatible` + flag `chatbot_llm`). Avant de l'activer, vérifier où le fournisseur héberge les données, au regard de la loi 18-07.

G.5 Nom de domaine

Enregistrement	Valeur	Remarque
`A gofix-digital.dz`	IP publique du VPS	Vérifier avec `nslookup gofix-digital.dz`
`A www.gofix-digital.dz`	IP publique du VPS	Nécessaire pour le certificat « www »
`MX`	Serveurs de messagerie d'Algérie Télécom	Ne pas modifier (Admail)

H BACK-OFFICE & EXPLOITATION

Administrer la plateforme au quotidien

H.1 Accès

`https://gofix-digital.dz/admin`, avec le compte `ADMIN_EMAIL`. Ce compte est recréé, ou son mot de passe réinitialisé, à chaque démarrage à partir du `.env` : en cas d'oubli, modifier `ADMIN_PASSWORD` puis lancer `docker compose up -d backend`. Créer ensuite des comptes nominatifs pour l'équipe (inscription normale, puis rôle admin attribué par le super-admin).

H.2 Rôles d'administration

Rôle	Accès
super_admin	Tout, y compris feature flags, paramètres, offres et matrice de déverrouillage, rôles admin, journal d'audit, registre des traitements. Seul à pouvoir suspendre un autre administrateur.
moderator	Utilisateurs (suspension et réactivation avec motif), validation des pièces, signalements, litiges, Trust Score (recalcul, contestations), taxonomie, tickets.
support	Consultation des utilisateurs, des validations, des litiges et des paiements ; traitement des tickets ; gestion de la FAQ.

H.3 Onglets du back-office

Onglet	Usage
Tableau de bord	Inscriptions, demandes, abonnements, files en attente
Utilisateurs	Recherche, suspension et réactivation (motif obligatoire, audité)
Validation	Pièces des pros et profs : consulter, valider, refuser avec motif, marquer « faux document » (forte baisse du Trust, audité)
Signalements	Traiter les signalements, avec suspension possible du compte visé
Litiges	Donner raison au client ou au pro : les deux parties sont notifiées et le Trust est recalculé
Trust	Contestations, recalcul avec motif journalisé, décisions AI MATCH récentes (explicabilité)
Tickets	Messages du formulaire de contact et du chatbot
FAQ	Questions et réponses FR/AR du chatbot ; liste des questions restées sans réponse
Offres	Prix, contenu des offres, matrice de déverrouillage (champs visibles selon l'offre)
Paiements	Commandes, statuts, factures

Onglet	Usage
Société & mentions légales	Super-admin : raison sociale, RC, NIF, NIS, article d'imposition, adresse, contacts, ANPDP, version et date des textes légaux, case « validés par un juriste » — affichés dans les pages légales (site et app) et sur les factures
Moyen de paiement	Super-admin : choix SATIM / test, accès marchand SATIM (mot de passe chiffré), URL de retour, test de connexion (G.2)
Taxonomie	Familles, métiers, rôles, spécialités, matières, niveaux ; demandes de nouvelles catégories
Flags / Paramètres	Activation des modules et réglages, sans redéploiement
Journal d'audit	Qui a fait quoi, quand, sur quoi, depuis quelle IP

H.4 Routine quotidienne de modération (15 à 30 min)

1. **Validation** : traiter les pièces en attente (un pro non validé reste peu visible).
2. **Signalements et litiges** : décision motivée, idéalement sous 48 h.
3. **Contestations Trust** : vérifier les événements contestés, recalculer si nécessaire. On ne modifie jamais une note à la main.
4. **Tickets** : répondre et clôturer.
5. **FAQ** : transformer les questions sans réponse du chatbot en nouvelles entrées FR + AR.
6. **Taxonomie** : accepter ou refuser les demandes de nouvelles catégories.

H.5 Feature flags

Flag	Défaut	Effet
`ai_match`	Activé	Recherche intelligente et classement AI MATCH
`trust_score`	Activé	Affichage du Trust Score
`online_payment`	Activé	Paiement en ligne des offres
`chatbot`	Activé	Bulle d'assistance
`push_notifications`	Activé	Notifications push sur les téléphones qui les ont acceptées (service Expo → APNs / FCM)
`remote_courses`	Activé	Univers « Cours à distance » sur l'accueil
`auth_phone_otp`	Désactivé	Connexion par code SMS (exige une passerelle SMS)
`chatbot_llm`	Désactivé	Reformulation par IA (exige `LLM_*`)
`vision`, `edu_ai`, `voice`, `pro_ai`, `passport`	Désactivés	Modules « à venir » : ne pas activer avant leur développement
`video_calls`	Désactivé	Visioconférence (hors V1)

H.6 Paramètres importants

Paramètre	Défaut	Signification
`free_access_days` / `free_access_max_requests`	30 / 5	Accès gratuit d'un nouveau pro ou prof
`minor_age_threshold`	18	Âge sous lequel le consentement parental est requis (à confirmer par un juriste)
`request_max_recipients`	5	Destinataires maximum par demande
`match_weights` / `match_top_n`	30/20/10/20/15/5 · 5	Pondérations AI MATCH (métier, proximité, disponibilité, Trust, avis, réactivité) et nombre de résultats
`trust_rules_v2`	25/20/30/25	Poids identité / réactivité / satisfaction / fiabilité
`job_auto_complete_hours`	72	Validation automatique d'un rendez-vous terminé
`job_dispute_window_days`	7	Délai pour ouvrir un litige
`job_late_cancel_hours`	24	En dessous, l'annulation pénalise la fiabilité du pro
`subscription_reminder_days`	7, 3, 1	Relances avant expiration
`payment_timeout_minutes`	30	Expiration d'une commande non payée
`app_store_url` / `play_store_url`	vides	Liens vers l'application sur l'App Store et Google Play (https uniquement). Vides : boutons « Bientôt » ; renseignés : boutons actifs sur l'accueil et la page `/app`
`data_retention_months`	36/12/24/120	Conservation : comptes inactifs / audit / messages / paiements

H.7 Sauvegardes

```
./scripts/backup_mongo.sh                          # base → backups/gofix-<db>-<date>.archive.gz (14 jours conservés)
./scripts/restore_mongo.sh backups/<fichier>       # restauration (remplace la base)
# fichiers envoyés (photos, pièces) :
docker run --rm -v gofix_storage_data:/d -v /opt/gofix/backups:/b alpine tar czf /b/storage-$(date +%F).tar.gz -C /d .
# planification (crontab -e) : base chaque nuit à 2 h 30, fichiers chaque dimanche
30 2 * * * cd /opt/gofix && ./scripts/backup_mongo.sh >> backups/backup.log 2>&1
0 3 * * 0 docker run --rm -v gofix_storage_data:/d -v /opt/gofix/backups:/b alpine tar czf /b/storage-$(date +\%F).tar.gz -C /d .
```

Règle des 3 copies

Copier chaque semaine le dossier `backups/` hors du VPS, sur un support situé en Algérie, et **tester une restauration chaque mois** sur un poste de développement. Le volume s'appelle `<nom du dossier>_storage_data` : `gofix_storage_data` si le code est dans `/opt/gofix` (vérifier avec `docker volume ls`).

H.8 Journaux et surveillance

- `docker compose logs -f backend` : journaux JSON (identifiant de requête, durée, statut). Un utilisateur qui signale une erreur peut fournir le `request_id` affiché.
- `/api/health` : à surveiller toutes les 5 minutes avec un outil de disponibilité externe, avec alerte par e-mail.
- aaPanel → *Monitor* : CPU, mémoire, disque. Alerte si le disque dépasse 80 % (sauvegardes, images Docker).
- Journal d'audit du back-office : à relire chaque semaine (suspensions, changements de flags et de rôles).

H.9 Limites connues à garder en tête

- Le backend tourne avec **un seul processus** : le limiteur anti-abus est en mémoire. Il faudra passer à Redis avant de multiplier les instances.
- Un redémarrage du backend remet à zéro les compteurs anti-abus en mémoire. Les verrouillages de compte, stockés en base, sont conservés.

I SÉCURITÉ & CONFORMITÉ

Mesures en place, audit d'octobre 2026 et obligations légales

1. Mesures en place

Domaine	Mesure
Authentification	Mots de passe bcrypt ; jeton d'accès de 15 min ; jeton de rafraîchissement de 30 j avec rotation et détection de réutilisation ; verrouillage après 5 échecs par IP et 10 échecs par compte (15 min).
Autorisation	Rôles vérifiés par l'API sur chaque route ; floutage et droits d'abonnement calculés côté serveur ; seul le super-admin agit sur les administrateurs.
Transport	HTTPS via aaPanel, HSTS ; jetons dans SecureStore sur mobile.
Navigateur	CSP stricte (aucun script externe ni inline), `X-Frame-Options DENY`, `nosniff`, `Referrer-Policy`, `Permissions-Policy`.
Fichiers	Contrôle du contenu réel (PDF, JPEG, PNG, WebP), 10 Mo maximum ; photos ré-encodées (métadonnées EXIF supprimées) ; pièces d'identité en stockage privé, consultables par l'admin dans un « bac à sable ».
Abus	Limites de débit sur la connexion, l'inscription, les codes SMS, le mot de passe oublié (3 par heure par adresse), le contact, les cookies et le retour de paiement.
Paiement	Page hébergée SATIM ; statut vérifié serveur à serveur ; activation idempotente ; montants fixés par le serveur ; mode fictif interdit en production.
Configuration	Refus de démarrer avec une configuration faible ; documentation de l'API masquée en production ; MongoDB non exposé et protégé par mot de passe.
Données personnelles	Export JSON ; suppression avec effacement des fichiers et anonymisation des traces partagées ; journal d'audit ; consentements horodatés.

2. Audit de sécurité (octobre 2026)

Revue complète du code, de la configuration et des dépendances. **15 points corrigés**, chacun couvert par un test automatisé. Les plus importants : usurpation d'IP permettant de contourner les limites, attaque par force brute répartie sur plusieurs IP, démarrage possible en production avec une configuration de développement (dont un paiement fictif), absence d'en-têtes de sécurité, droits excessifs des modérateurs sur les administrateurs, contrôle du type de fichier fondé sur la déclaration du client, effacement incomplet des comptes. Détail complet : `docs/SECURITY_AUDIT.md`.

Risque résiduel accepté en V1	Plan
Pas de double authentification pour les admins	V1.1 (TOTP) ; d'ici là, mots de passe forts et comptes nominatifs
Jetons du site web stockés dans le navigateur	Atténué par la CSP ; passage à un cookie `HttpOnly` envisagé

Risque résiduel accepté en V1	Plan
Pièces d'identité non chiffrées au niveau applicatif	Demander le chiffrement du disque à l'hébergeur ; chiffrement applicatif en V1.1
Outils de compilation (react-scripts) signalés par npm audit	Non livrés aux navigateurs ; migration vers Vite prévue

3. Loi n° 18-07 (protection des données personnelles)

- **Déclaration** du traitement auprès de l'ANPDP avant l'ouverture ; le registre des traitements est exportable depuis le back-office (super-admin).
- **Pages légales** à faire valider par un juriste algérien : mentions, CGU, CGV, confidentialité.
- **Droits des personnes** : export et suppression accessibles depuis « Mon compte » (site et app).
- **Mineurs** : consentement parental sous le seuil défini (`minor_age_threshold`) ; données pédagogiques minimales.
- **Conservation** : durées définies dans `data_retention_months` .

4. Procédure en cas d'incident

1. **Isoler** : couper l'accès public (désactiver le reverse proxy dans aaPanel) sans éteindre les conteneurs, pour conserver les traces.
2. **Conserver les preuves** : `docker compose logs > incident-$(date +%F).log` , export du journal d'audit, sauvegarde de la base.
3. **Changer les secrets** : `JWT_SECRET` (déconnecte tout le monde), `ADMIN_PASSWORD` , mots de passe MongoDB, SMTP, aaPanel, root ; faire régénérer le mot de passe marchand SATIM par la banque et le ressaisir dans le back-office (« Moyen de paiement »).
4. **Corriger**, tester, redéployer, puis rouvrir l'accès.
5. **Informer** la direction ; en cas de fuite de données personnelles, évaluer avec le juriste les obligations de notification.

J

APPLICATION MOBILE

Configurer, compiler et publier l'application iOS / Android

1. Principe

L'application (dossier `mobile/`) utilise exactement la même API que le site : mêmes comptes, mêmes données, mêmes règles. Le back-office reste sur le web. Identifiant : `dz.gofix.app` (Android et iOS). Schéma de lien profond : `gofix://` (retour de paiement).

2. Configuration de production

- `EXPO_PUBLIC_API_URL=https://gofix-digital.dz` au moment de la compilation (HTTPS obligatoire).
- Côté serveur : `MOBILE_APP_SCHEME=gofix`.
- Incrémenter `version` dans `mobile/app.json` à chaque publication.
- Une fois l'application publiée, coller ses liens dans le back-office → *Paramètres* → `app_store_url` et `play_store_url` : l'accueil du site et la page `/app` redirigent alors vers les stores, sans redéploiement.

3. Compiler

```
cd mobile
npm install
npx expo prebuild                                  # génère android/ et ios/ (jamais modifiés à la main)
EXPO_PUBLIC_API_URL=https://gofix-digital.dz npx expo run:android --variant release   # Android Studio requis
EXPO_PUBLIC_API_URL=https://gofix-digital.dz npx expo run:ios --configuration Release # Mac + Xcode requis
# Option cloud (facultative) : npx eas-cli@latest build --platform all
```

4. Publier sur les stores

Store	Prérequis	Éléments à préparer
Google Play	Compte développeur Google Play (frais uniques), fichier AAB signé ; conserver la clé de signature en lieu sûr	Icône, captures (téléphone), description FR/AR, URL de confidentialité `https://gofix-digital.dz/legal/privacy`, formulaire « sécurité des données », compte de test pour la revue
App Store	Apple Developer Program (abonnement annuel), Mac avec Xcode, fiche App Store Connect	

Compte de test pour les revues

Apple et Google demandent un compte pour tester l'application. Créer un compte dédié en production (pas un compte de démonstration du seed), puis le désactiver après validation.

5. Notifications push et localisation

- **Notifications** : écran d'explication puis autorisation du téléphone (une seule fois, après la connexion) ; le jeton de l'appareil est enregistré (`push_tokens`) et chaque notification du site (réponse, message, rendez-vous, abonnement) est aussi envoyée sur le téléphone. Toucher la notification ouvre l'écran concerné. Configuration Firebase / Apple : Guide d'installation, E.3b.
- **Localisation** : facultative, approximative (position précise bloquée sur Android), demandée seulement quand l'utilisateur appuie sur « Détecter ma wilaya » ou « Près de moi ». L'API renvoie la wilaya la plus proche et ne conserve pas la position.
- **Profil** : chaque compte peut modifier nom, e-mail, téléphone (à revérifier), wilaya, et ajouter une photo facultative (visible par l'interlocuteur dans la messagerie).

Visites guidées

Site : `frontend/src/components/tour/` (définitions dans `tours.js` , cibles = `data-testid`). Application : `mobile/src/components/tour.jsx` (`<TourTarget id>` autour des éléments, `useScreenTour()` dans l'écran). Textes : `tour.*` dans `fr.lots2.js` / `ar.lots2.js` . Chaque visite se lance une fois (mémorisée dans `gofix_tours_done`) ; les tests automatiques posent `gofix_tours_done = "all"` pour ne pas être bloqués par la bulle.

6. Traductions

Les textes viennent des dictionnaires du site. Après toute modification côté web : `npm run i18n:sync` dans `mobile/` . Les textes propres à l'app sont dans `mobile/src/i18n/mobile.js` . Le passage à l'arabe redémarre l'app pour activer le RTL natif.

K

RÉFÉRENCE API

Endpoints /api/v1 par module (détail des champs : /api/docs en développement)

Module	Endpoints	Accès
Santé	`GET /api/health`	Public
Authentification `/auth`	register, login, refresh, logout, me, otp/request, otp/verify, password/forgot, password/reset	Public / Bearer
Compte `/users/me`	PATCH profil (nom, e-mail, téléphone, wilaya, préférences), POST/DELETE photo, POST push-tokens (+ /remove), POST roles, PUT mode, GET export, DELETE (mot de passe requis)	Bearer
Référentiels	geo/wilayas, geo/wilayas/{code}/communes, geo/locate (wilaya la plus proche d'une position, non conservée), taxonomy/families · categories · roles · specialties, academy/subjects · levels	Public
Catalogue	catalog/professionals, catalog/teachers, catalog/…/{id}, files/public/{clé}	Public (floutage selon l'offre)
AI MATCH `/match`	POST parse, POST recommend, POST feedback, GET explanations/{id}	Public / Bearer
Trust `/trust`	GET profiles/{kind}/{id}, POST appeals, POST events/…, POST recompute/… (admin)	Public / Bearer / Admin
Inscription pro `/onboarding`	status, draft (GET/PUT/DELETE), photo, cover, documents, category-requests, submit	Bearer
Espace pro `/provider`	me, profile, media/{photo|cover}, documents, trust/contest	Bearer (pro / prof)
Demandes	POST requests, requests/mine, requests/{id}/close, requests/inbox, requests/{id}/respond, POST reports	Bearer
Rendez-vous `/jobs`	POST, GET, GET {id}, confirm, cancel, complete, dispute, review	Bearer
Social	favorites, conversations (+ messages, unread-count), notifications (+ read-all)	Bearer
Paiement `/billing`	plans, me, orders, orders/{n}, orders/{n}/confirm, callback/{provider}, invoices/{n}, invoices/{n}/pdf	Bearer / SATIM
Public	config, consents/cookies, contact, faq ; chatbot/ask, chatbot/faq/{id}, chatbot/handoff	Public
Admin `/admin`	stats, dashboard, users (+ status, admin-role), feature-flags, settings, audit-logs, processing-register, faq, chatbot/unanswered, plans, unlock-matrix, reports, tickets, trust/contests, category-requests, profiles (+ documents, verification), taxonomy/{kind}, disputes, payments, matching/stats, match-results	Admin (selon rôle)

Conventions

- Authentification : en-tête `Authorization: Bearer <access_token>`.
- Erreurs : `{"detail": "code"}` (ex. `invalid_credentials`, `too_many_attempts`, `account_suspended`, `rate_limited`).
- Dates en UTC (ISO 8601) ; les interfaces les affichent à l'heure d'Alger.
- Toute réponse porte un en-tête `X-Request-ID`, utile pour retrouver une requête dans les logs.

L DÉPANNAGE

Symptômes fréquents, causes probables et solutions

Symptôme	Cause probable	Solution
« 502 Bad Gateway » sur le site	Stack GoFix arrêtée ou mauvais port dans aaPanel	`docker compose ps` ; `curl http://127.0.0.1:8080/api/health` ; vérifier la cible `http://127.0.0.1:8080`
Le backend redémarre en boucle	Configuration de production refusée	`docker compose logs backend` → corriger les valeurs citées dans le `.env`
MongoDB s'arrête avec « Illegal instruction »	Processeur virtuel sans AVX	Voir F.3 (CPU « host » ou image `mongo:4.4`)
MongoDB « Authentication failed »	Identifiants ajoutés sur un volume déjà initialisé	Les variables `MONGO_ROOT_*` ne s'appliquent qu'au premier démarrage : créer l'utilisateur manuellement ou repartir d'un volume neuf restauré depuis une sauvegarde
Aucun e-mail reçu	`EMAIL_PROVIDER=console`, mauvais port ou identifiants SMTP	Logs « email » du backend ; port 465 (SSL) ou 587 (STARTTLS) ; dossier spam ; abonnement Admail actif
« Paiement momentanément indisponible »	SATIM non choisi ou incomplet (mode simulé interdit en production)	Back-office → *Moyen de paiement* : choisir SATIM, compléter, enregistrer, tester
Paiement : « service de paiement injoignable » (502)	URL SATIM erronée, identifiants refusés ou serveur sans accès réseau	« Tester la connexion » dans *Moyen de paiement* ; logs `satim_call` du backend
« Mot de passe enregistré illisible » dans *Moyen de paiement*	`CONFIG_ENCRYPTION_KEY` ou `JWT_SECRET` modifié	Ressaisir le mot de passe SATIM et enregistrer
Tout le monde est bloqué « Trop de tentatives »	IP réelle non transmise par aaPanel	Ajouter `X-Forwarded-For` dans la configuration du site (F.7)
Un utilisateur est bloqué à la connexion	5 échecs depuis son IP ou 10 échecs sur son compte	Attendre 15 min, ou utiliser « Mot de passe oublié »
Envoi de photo refusé (413)	Taille maximale trop basse dans aaPanel	`client_max_body_size 10m;` dans la configuration du site
Envoi de pièce refusé (415)	Fichier qui n'est pas un vrai PDF ou une vraie image	Exporter de nouveau le document en PDF, JPEG ou PNG
Page blanche après une mise à jour	Ancienne version en cache (PWA)	Rechargement forcé ; vérifier la console du navigateur (erreur CSP éventuelle)

Symptôme	Cause probable	Solution
La compilation du site échoue (mémoire)	RAM insuffisante	Ajouter de la mémoire d'échange (F.3)
Mot de passe admin perdu	—	Modifier `ADMIN_PASSWORD` dans le `.env`, puis `docker compose up -d backend`
Disque plein	Images Docker et sauvegardes	`docker image prune -f` ; déplacer les anciennes sauvegardes hors du serveur

M

FEUILLE DE ROUTE & AIDE-MÉMOIRE

Prochaines étapes produit et techniques, commandes utiles

1. Modules « à venir » (ordre du cahier des charges)

Phase	Contenu	Pré-requis déjà en place
Phase 2 – Acquisition	VOICE™ + VISION™	Schéma d'intention AI MATCH, flags, stockage des médias
Phase 3 – Éducation	EDU AI™	Taxonomie scolaire administrable, Trust des professeurs
Phase 4 – Monétisation pro	PRO AI™ + PASSPORT™	Abonnements contrôlés côté serveur, champs `ai{}` et `passport{}`

2. Améliorations techniques recommandées

Priorité	Action	Bénéfice
1	Dépôt Git privé + intégration continue (tests à chaque modification)	Historique, retour arrière, aucune régression
2	Double authentification (TOTP) pour les administrateurs	Exigence du cahier des charges (MFA admin)
3	Surveillance externe de `/api/health` avec alertes	Détection immédiate des pannes
4	Chiffrement des pièces d'identité au repos	Protection des données sensibles
5	Migration de Create React App vers Vite	Compilation plus rapide, dépendances à jour
6	Limiteur de débit sur Redis, stockage objet (MinIO)	Montée en charge sur plusieurs instances
7	Liste complète des 1 541 communes (`backend/app/data/communes.json`)	Zones d'intervention plus précises

3. Aide-mémoire

```
# État et journaux
docker compose ps
docker compose logs -f backend
curl -s http://127.0.0.1:8080/api/health
# Redémarrer / mettre à jour
docker compose up -d                      # après modification du .env
docker compose up -d --build              # après mise à jour du code
docker compose restart nginx              # après modification de deploy/nginx/conf.d
# Données
docker compose exec backend python -m app.seed --reference-only
./scripts/backup_mongo.sh
./scripts/restore_mongo.sh backups/<fichier>
# Tests (poste de développement)
docker compose --profile test run --rm tests
# Régénérer ce dossier en PDF
python scripts/build_docs.py
```

Décision recommandée

Mettre en ligne la V1 sur gofix-digital.dz en suivant la section F, avec les paiements en environnement de test SATIM tant que la certification n'est pas obtenue. Activer ensuite les paiements réels, publier l'application mobile, puis lancer la phase 2 (VOICE™ et VISION™) sur la base des retours des premiers utilisateurs.

Fin du document — GOFIX DIGITAL